

11.3 IT-Sicherheitsbeauftragter

Der IT-Sicherheitsbeauftragte (ITSB) ist für die Planung, Umsetzung und Überwachung der IT-Sicherheitsmaßnahmen in einem Unternehmen verantwortlich. Er arbeitet an der Risikominimierung und Einhaltung gesetzlicher Vorgaben.

Aufgaben

- Entwicklung und Umsetzung von Sicherheitsrichtlinien
- Überwachung der Einhaltung von IT-Sicherheitsstandards (z. B. ISO 27001, BSI-Grundschutz)
- Durchführung von Risikoanalysen und Schwachstellenbewertungen
- Koordination von Maßnahmen zur IT-Sicherheit (Firewalls, Verschlüsselung, Zugriffskontrollen)
- Schulung und Sensibilisierung der Mitarbeiter in IT-Sicherheitsfragen
- Zusammenarbeit mit Datenschutzbeauftragten und IT-Abteilungen
- Reaktion auf Sicherheitsvorfälle und Notfallmanagement

Rechtliche Grundlagen und Anforderungen

- Kein gesetzlich vorgeschriebener Pflichtposten, aber empfohlen nach IT-Sicherheitsgesetz (IT-SiG)
- DSGVO fordert angemessene Schutzmaßnahmen, die durch einen ITSB koordiniert werden können
- In Unternehmen mit kritischer Infrastruktur (KRITIS) kann ein ITSB erforderlich sein

Anforderungen

- Fachwissen in IT-Sicherheit, Netzwerksicherheit und Datenschutz
- Kenntnisse in IT-Sicherheitsstandards und Compliance-Anforderungen
- Kommunikationsstärke und Fähigkeit zur Schulung von Mitarbeitern
- Erfahrung in Risikomanagement und Incident Response

11.4 Datenschutzbeauftragter

Der Datenschutzbeauftragte (DSB) ist für die Überwachung und Einhaltung des Datenschutzes gemäß DSGVO (Art. 37–39) verantwortlich. Er berät das Unternehmen in Datenschutzfragen und stellt sicher, dass personenbezogene Daten rechtskonform verarbeitet werden.

Aufgaben

- Überwachung der Einhaltung der DSGVO und des BDSG
- Beratung der Geschäftsleitung und Mitarbeiter zu Datenschutzfragen
- Erstellung und Pflege von Datenschutzrichtlinien und -konzepten
- Durchführung von Datenschutz-Folgenabschätzungen (DPIA)
- Schulung und Sensibilisierung der Mitarbeiter
- Zusammenarbeit mit der Aufsichtsbehörde bei Datenschutzvorfällen
- Kontrolle der Technisch-organisatorischen Maßnahmen (TOM)

Wann ist ein Datenschutzbeauftragter erforderlich?

Ein Unternehmen muss einen DSB benennen, wenn:

- Es mindestens 20 Personen mit der automatisierten Verarbeitung personenbezogener Daten beschäftigt (§ 38 BDSG).
- Die Kerntätigkeit in der umfangreichen Verarbeitung sensibler Daten (z. B. Gesundheitsdaten) besteht.
- Es eine behördliche oder öffentliche Stelle ist.

Anforderungen

- Fachkunde im Datenschutzrecht und IT-Sicherheit
- Unabhängigkeit und Weisungsfreiheit
- Vermeidung von Interessenkonflikten (z. B. keine gleichzeitige IT-Leitung)

11.5 IT-Sicherheitsrichtlinien

IT-Sicherheitsrichtlinien sind verbindliche Vorgaben eines Unternehmens zur Gewährleistung von Verfügbarkeit, Vertraulichkeit und Integrität von IT-Systemen und Daten. Sie definieren Regeln und Maßnahmen zum Schutz vor Cyberangriffen, Datenverlust und unbefugtem Zugriff.

Inhalte einer IT-Sicherheitsrichtlinie

1. Zugriffs- und Berechtigungskonzepte
 - Nutzung von starken Passwörtern und Multi-Faktor-Authentifizierung (MFA)
 - Prinzip der minimalen Rechtevergabe (Least Privilege Principle)
 - Regelungen für Gast- und externe Zugriffe
2. Umgang mit Daten und Speichermedien
 - Verschlüsselung sensibler Daten (z. B. AES, TLS)
 - Regelungen zur Datenklassifizierung (öffentlich, vertraulich, geheim)
 - Sichere Datenspeicherung und -löschung
3. Netzwerksicherheit
 - Einsatz von Firewalls, VPNs und Intrusion Detection Systems (IDS)
 - Regeln für WLAN-Nutzung und Remote-Zugriff
 - Schutzmaßnahmen gegen DDoS- und Man-in-the-Middle-Angriffe
4. Endgerätesicherheit
 - Verwendung von Antivirensoftware und Endpoint Protection
 - Regelmäßige Updates und Patches für Betriebssysteme und Anwendungen
 - Verbot oder Einschränkung privater Geräte (BYOD-Richtlinien)
5. Incident Management & Notfallpläne
 - Meldewege für Sicherheitsvorfälle und Datenschutzverletzungen
 - Definition von Reaktionsmaßnahmen bei Cyberangriffen
 - Regelmäßige Backups und Disaster-Recovery-Tests
6. Mitarbeitersensibilisierung & Schulungen
 - Schulungen zu IT-Sicherheit & Social Engineering
 - Richtlinien für E-Mail-Sicherheit (Phishing-Erkennung)

- Vorgaben für sicheres Arbeiten im Homeoffice

Ziel der IT-Sicherheitsrichtlinien

- Schutz der IT-Infrastruktur vor Angriffen und Bedrohungen
- Einhaltung gesetzlicher Vorgaben (DSGVO, IT-Sicherheitsgesetz, ISO 27001)
- Minimierung von Risiken durch klare Sicherheitsvorgaben

11.6 Personelle Maßnahmen und Entwicklung des Sicherheitsbewusstseins

Personelle Maßnahmen sind organisatorische Vorkehrungen zur Sensibilisierung von Mitarbeitern für IT-Sicherheit. Da menschliches Fehlverhalten eine häufige Ursache für Sicherheitsvorfälle ist, sind Schulungen und klare Verhaltensrichtlinien essenziell.

Schulungen

- Regelmäßige IT-Sicherheitsschulungen für alle Mitarbeiter
- Phishing-Tests zur Sensibilisierung für Social Engineering
- Workshops zu sicherem Umgang mit Passwörtern & Authentifizierungsmethoden
- E-Learning-Programme für flexibles Lernen

Klare Verhaltensrichtlinien

- Nutzung von starken Passwörtern und Multi-Faktor-Authentifizierung (MFA)
- Keine Weitergabe von Zugangsdaten oder sensiblen Informationen
- Sichere Nutzung von E-Mails & Anhängen (Phishing-Prävention)
- Regelungen für mobiles Arbeiten & Homeoffice-Sicherheit

Zugriffskontrollen & Berechtigungskonzepte

- Least Privilege Principle: Mitarbeiter erhalten nur notwendige Rechte
- Rollenbasierte Zugriffskontrollen (RBAC) zur Einschränkung sensibler Datenzugriffe

- Dokumentation & Protokollierung von Zugriffen

Förderung der Sicherheitskultur im Unternehmen

- Mitarbeiter zu Botschaftern der IT-Sicherheit machen
- Meldesysteme für Sicherheitsvorfälle etablieren (ohne Angst vor Sanktionen)
- Belohnung sicherheitsbewussten Verhaltens (z. B. Gamification-Ansätze)

Ziel der personellen Maßnahmen

- Reduzierung von Sicherheitsrisiken durch menschliches Fehlverhalten
- Bewusstseinsbildung für IT-Sicherheit im Arbeitsalltag
- Langfristige Stärkung der Sicherheitskultur im Unternehmen

11.7 BSI IT-Grundschutz-Kompendium

Das BSI IT-Grundschutz-Kompendium ist ein Standardwerk des Bundesamts für Sicherheit in der Informationstechnik (BSI) zur Umsetzung von IT-Sicherheitsmaßnahmen in Unternehmen und Behörden. Es basiert auf einem systematischen Ansatz zur Identifikation und Minimierung von Risiken.

IT-Grundschutz-Methodik

Der IT-Grundschutz umfasst:

- Basis-Sicherheitsmaßnahmen für typische IT-Umgebungen
- Gefährdungskataloge zur Identifikation von Risiken
- Schutzbedarfsermittlung für IT-Systeme und Daten
- Umsetzungsplanung von Sicherheitsmaßnahmen

Schichtenmodell des IT-Grundschutzes

Sicherheitsmaßnahmen werden in fünf Schichten unterteilt:

1. Übergreifende Aspekte (Sicherheitsmanagement, Personal, Notfallmanagement)
2. Prozesse und Organisation (Betriebs- und Sicherheitskonzepte)
3. Netze und Kommunikation (Firewalls, VPNs, Netzwerksicherheit)
4. IT-Systeme (Clients, Server, Mobile Geräte)

5. Anwendungen (Webanwendungen, Cloud-Dienste, E-Mail-Sicherheit)

IT-Grundschutz-Bausteine

Das Kompendium gliedert Sicherheitsmaßnahmen in **Bausteine**, darunter:

- **ORP:** Organisation und Personal (z. B. Sicherheitsrichtlinien, Schulungen)
- **INF:** Infrastruktur (z. B. Rechenzentren, Verkabelung)
- **NET:** Netzwerke (z. B. WLAN-Sicherheit, Firewalls)
- **SYS:** IT-Systeme (z. B. Server, Clients, Virtualisierung)
- **APP:** Anwendungen (z. B. Webanwendungen, Datenbanken)

Schutzmaßnahmen nach IT-Grundschutz

- **Technische Maßnahmen:** Firewalls, Verschlüsselung, Zugriffskontrollen
- **Organisatorische Maßnahmen:** Sicherheitsrichtlinien, Notfallpläne
- **Personelle Maßnahmen:** Sensibilisierung, Schulungen
- **Physische Maßnahmen:** Zutrittskontrollen, Schutz von Rechenzentren

11.8 Datenschutzgesetze

Die Einhaltung der Datenschutzgesetze, insbesondere der DSGVO (Datenschutz-Grundverordnung) und des BDSG (Bundesdatenschutzgesetz), muss regelmäßig überprüft werden, um Datenschutzverstöße zu vermeiden und gesetzliche Anforderungen zu erfüllen.

Datenschutz-Grundverordnung (DSGVO)

Die DSGVO (EU-weit gültig) regelt den Schutz personenbezogener Daten.

Prüfkriterien:

- **Rechtmäßigkeit der Verarbeitung:** Liegt eine Rechtsgrundlage vor (z. B. Einwilligung, Vertrag, berechtigtes Interesse)?
- **Datensparsamkeit:** Werden nur die notwendigen Daten erhoben?

- **Transparenz:** Werden Betroffene über die Datenverarbeitung informiert (Art. 13, 14 DSGVO)?
- **Betroffenenrechte:** Können Personen Auskunft, Berichtigung oder Löschung ihrer Daten verlangen?
- **Technisch-organisatorische Maßnahmen (TOM):** Sind angemessene Sicherheitsmaßnahmen implementiert (z. B. Verschlüsselung, Zugriffskontrollen)?
- **Meldung von Datenschutzverletzungen:** Sind Prozesse zur Meldepflicht bei Datenschutzpannen (Art. 33 DSGVO) vorhanden?
- **Datenschutz-Folgenabschätzungen (DPIA):** Wurden für risikobehaftete Verarbeitungen Folgenabschätzungen durchgeführt (Art. 35 DSGVO)?
- **Verarbeitungsverzeichnis:** Existiert eine Dokumentation aller Datenverarbeitungen im Unternehmen (Art. 30 DSGVO)?
- **Auftragsverarbeitung:** Sind Verträge mit externen Dienstleistern datenschutzkonform (Art. 28 DSGVO)?

Bundesdatenschutzgesetz (BDSG)

Das BDSG ergänzt die DSGVO und enthält nationale Datenschutzregelungen für Deutschland.

Prüfkriterien:

- **Bestellung eines Datenschutzbeauftragten:** Ist ein DSB benannt, falls erforderlich (§ 38 BDSG)?
- **Besonderer Schutz sensibler Daten:** Werden besonders schützenswerte Daten (z. B. Gesundheitsdaten, biometrische Daten) gemäß § 22 BDSG gesichert?
- **Beschäftigtendatenschutz:** Werden Daten von Mitarbeitern nur im zulässigen Rahmen verarbeitet (§ 26 BDSG)?
- **Videoüberwachung:** Werden die rechtlichen Vorgaben für Kameraüberwachung eingehalten (§ 4 BDSG)?

11.8 Personenbezogene Daten

Personenbezogene Daten sind gemäß Art. 4 Nr. 1 DSGVO alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person beziehen.

Beispiele für personenbezogene Daten

Direkte Identifikation:

- Name, Vorname
- Adresse
- Telefonnummer
- E-Mail-Adresse (z. B. max.mustermann@example.com)

Indirekte Identifikation:

- IP-Adresse
- Kundennummer
- Standortdaten
- Cookie-IDs

Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO):

- Gesundheitsdaten
- Biometrische Daten (Fingerabdruck, Gesichtserkennung)
- Politische Meinungen
- Religiöse Überzeugungen

11.10 Rechte der Betroffenen und Konsequenzen der Einwilligung

Die DSGVO räumt betroffenen Personen umfassende Rechte ein, um die Kontrolle über ihre personenbezogenen Daten zu gewährleisten. Eine Verarbeitung personenbezogener Daten ist nur zulässig, wenn eine Rechtsgrundlage vorliegt, darunter die Einwilligung der betroffenen Person (Art. 6 Abs. 1 lit. a DSGVO).

Rechte der Betroffenen (Art. 12–22 DSGVO)

Recht auf Information (Art. 13, 14 DSGVO)

- Betroffene müssen über die Datenverarbeitung, Zwecke und Rechtsgrundlagen informiert werden.
- Dies erfolgt in der Datenschutzerklärung oder durch direkte Mitteilung.

Recht auf Auskunft (Art. 15 DSGVO)

- Betroffene können eine Kopie ihrer gespeicherten Daten anfordern.
- Unternehmen müssen zusätzlich angeben, woher die Daten stammen, an wen sie weitergegeben wurden und wie lange sie gespeichert werden.

Recht auf Berichtigung (Art. 16 DSGVO)

- Unrichtige oder unvollständige Daten müssen auf Antrag berichtigt werden.

Recht auf Löschung („Recht auf Vergessenwerden“, Art. 17 DSGVO)

- Personen können die Löschung ihrer Daten verlangen, wenn
 - die Daten nicht mehr benötigt werden,
 - die Einwilligung widerrufen wurde oder
 - eine unrechtmäßige Verarbeitung vorliegt.
- Ausnahmen bestehen, wenn eine gesetzliche Pflicht zur Aufbewahrung besteht.

Recht auf Einschränkung der Verarbeitung (Art. 18 DSGVO)

- Daten dürfen nur noch gespeichert, aber nicht mehr verarbeitet werden, wenn z. B. die Richtigkeit überprüft wird.

Recht auf Datenübertragbarkeit (Art. 20 DSGVO)

- Betroffene können verlangen, dass ihre Daten in einem maschinenlesbaren Format bereitgestellt oder an einen anderen Anbieter übertragen werden.

Widerspruchsrecht (Art. 21 DSGVO)

- Verarbeitung kann jederzeit aus persönlichen Gründen untersagt werden, es sei denn, es gibt zwingende schutzwürdige Gründe.

Recht auf keine automatisierte Entscheidung (Art. 22 DSGVO)

- Personen dürfen nicht allein durch automatisierte Entscheidungen benachteiligt werden (z. B. Kreditbewertung durch Algorithmen).

Konsequenzen der Einwilligung (Art. 7 DSGVO)

Die Einwilligung ist eine freiwillige, informierte und unmissverständliche Zustimmung zur Datenverarbeitung.

Voraussetzungen einer gültigen Einwilligung

- **Freiwilligkeit:** Keine Zwangslage oder Nachteile bei Verweigerung.
- **Informiertheit:** Klare Erklärung zu Zweck, Art und Umfang der Verarbeitung.
- **Eindeutige Handlung:** Opt-in-Verfahren, keine vorausgewählten Checkboxes.
- **Widerrufbarkeit:** Die Einwilligung kann jederzeit ohne Nachteile widerrufen werden.

Ungültige Einwilligung

- Wenn die betroffene Person nicht ausreichend informiert wurde.
- Wenn sie nicht aktiv zugestimmt hat (z. B. durch vorangekreuzte Felder).
- Wenn sie nicht freiwillig gegeben wurde (z. B. bei Abhängigkeitsverhältnissen).

Konsequenzen bei fehlender oder unwirksamer Einwilligung

- Die Verarbeitung ist rechtswidrig und kann Bußgelder nach Art. 83 DSGVO zur Folge haben.
- Betroffene können Beschwerde bei der Aufsichtsbehörde einlegen und Schadensersatz fordern.

11.11 Anonymisierung

Anonymisierung ist ein Verfahren zur unwiderruflichen Entfernung des Personenbezugs aus Daten. Nach der Anonymisierung können die Daten keiner bestimmten Person mehr zugeordnet werden und unterliegen nicht mehr der DSGVO.

Merkmale

- Keine Identifikation der betroffenen Person möglich
- Keine Rückführung der Daten auf die Person

- Dauerhafter Verlust des Personenbezugs

Methoden der Anonymisierung

- **Datenaggregation:** Zusammenfassung von Einzelwerten zu Gruppen (z. B. Durchschnittswerte statt individueller Daten).
- **Maskierung:** Ersetzung bestimmter Merkmale (z. B. Namen durch „XXX“).
- **Rauschen (Noise Addition):** Zufällige Veränderung der Daten, um Identifikation zu verhindern.
- **Generalization:** Reduzierung der Genauigkeit (z. B. „Alter 25“ → „Altersgruppe 20-30“).
- **k-Anonymität:** Daten sind nur dann freigegeben, wenn mindestens k Personen dieselben Merkmale teilen.

11.12 Pseudonymisierung

Pseudonymisierung ist ein Datenschutzverfahren, bei dem personenbezogene Daten so verändert werden, dass sie **ohne zusätzliche Informationen** nicht mehr einer bestimmten Person zugeordnet werden können. Die Zuordnung kann jedoch durch Verwendung eines Schlüssels wiederhergestellt werden.

Merkmale

- Der direkte Bezug zur Person wird durch **Ersetzung oder Verschlüsselung** entfernt.
- Die ursprünglichen Daten bleiben erhalten und sind durch einen **separaten Schlüssel** rekonstruierbar.
- Die Daten unterliegen weiterhin der DSGVO (Art. 4 Nr. 5 DSGVO), da die Identifikation theoretisch möglich bleibt.

Methoden der Pseudonymisierung

- **Ersatz durch Kennungen:** Zuweisung zufälliger Identifikatoren (z. B. Kundennummer statt Name).
- **Hashing:** Umwandlung von Daten in einen Hash-Wert (z. B. SHA-256), ohne Rückführungsmöglichkeit.
- **Tokenisierung:** Austausch sensibler Daten durch zufällige Token, die separat gespeichert werden.

- **Verschlüsselung:** Speicherung der Originaldaten in verschlüsselter Form mit separatem Schlüssel.

11.13 Schutzbedarfsanalyse

Die Schutzbedarfsanalyse bewertet die Sicherheitsanforderungen von Daten, IT-Systemen und Infrastruktur, um angemessene Schutzmaßnahmen abzuleiten.

Durchführung

Eine Schutzbedarfsanalyse erfolgt in mehreren Schritten:

1. **Identifikation der Schutzobjekte**
 - Welche Daten, Anwendungen, IT-Systeme, Räume oder Kommunikationsverbindungen müssen geschützt werden?
2. **Bewertung des Schutzbedarfs**
 - Welche Auswirkungen hätte ein Datenverlust, ein Ausfall oder eine Manipulation?
 - Schutzbedarf wird meist in niedrig, mittel und hoch eingeteilt.
3. **Ableitung von Schutzmaßnahmen**
 - Maßnahmen anhand des Schutzbedarfs auswählen (z. B. Verschlüsselung, Firewalls, Zugriffskontrollen).
4. **Dokumentation & Umsetzung**
 - Ergebnisse dokumentieren und regelmäßig überprüfen (z. B. durch Audits).

Schutzbedarfsanalyse für verschiedene Bereiche

Anwendungen

- Bewertung der Kritikalität einer Software (z. B. ERP-System, Webanwendung).
- Anforderungen an Datenintegrität, Verfügbarkeit und Vertraulichkeit.
- Schutz vor Manipulation, Datenverlust und unbefugtem Zugriff.

IT-Systeme

- Identifikation kritischer Server, Datenbanken, Endgeräte.
- Bewertung von Ausfallrisiken und Angriffsszenarien.

- Maßnahmen wie Backup-Strategien, Firewalls, Zugriffskontrollen.

Räume und Infrastruktur

- Schutz sensibler Bereiche (z. B. Rechenzentren, Büros mit vertraulichen Daten).
- Maßnahmen wie Zutrittskontrollen, Videoüberwachung, Brandschutz.

Kommunikationsverbindungen

- Bewertung von Netzwerkverbindungen, VPNs, Cloud-Diensten.
- Schutz durch Ende-zu-Ende-Verschlüsselung, Firewalls, IDS/IPS.

11.14 Arbeitsplatzbezogenes Sicherheitskonzept

Ein arbeitsplatzbezogenes Sicherheitskonzept definiert Maßnahmen zum Schutz von IT-Arbeitsplätzen gegen technische, organisatorische und menschliche Risiken.

Schutzbedarfskategorien

Der Schutzbedarf eines Arbeitsplatzes richtet sich nach den Auswirkungen eines Sicherheitsvorfalls:

- Normal → Keine gravierenden Folgen, Standardmaßnahmen ausreichend.
- Hoch → Betrifft vertrauliche Daten oder geschäftskritische Systeme, erweiterte Sicherheitsmaßnahmen nötig.
- Sehr hoch → Schwerwiegende wirtschaftliche oder rechtliche Konsequenzen, maximale Schutzmaßnahmen erforderlich.

Risiko-Klassifikation

Ein Arbeitsplatz wird anhand möglicher Bedrohungen und Auswirkungen klassifiziert:

Risiko	Beispiel	Schutzmaßnahme
Gering	Kein Zugriff auf interne Systeme	Standard-Passwortschutz
Mittel	Zugriff auf Kundendaten	2FA, Verschlüsselung
Hoch	Verarbeitung sensibler Daten	Härtung, Netzwerksegmentierung, Monitoring

11.15 ISMS

Ein ISMS (Information Security Management System) ist ein systematischer Ansatz zur Planung, Umsetzung, Überwachung und Verbesserung der Informationssicherheit in einer Organisation. Es basiert auf definierten Richtlinien, Prozessen und technischen Maßnahmen.

Bestandteile

- **Sicherheitsrichtlinien:** Vorgaben zur IT-Sicherheit und Datenschutz.
- **Risikomanagement:** Identifikation, Bewertung und Behandlung von Sicherheitsrisiken.
- **Technische & organisatorische Maßnahmen:** Firewalls, Verschlüsselung, Schulungen.
- **Überwachung & Audits:** Regelmäßige Prüfungen zur Einhaltung der Sicherheitsstandards.
- **Kontinuierliche Verbesserung:** Anpassung an neue Bedrohungen und Anforderungen.

Relevante Standards

- **ISO 27001:** Internationaler Standard für ISMS-Zertifizierung.
- **BSI IT-Grundschutz:** Deutscher Standard für IT-Sicherheit.

Vorteile

- Schutz sensibler Daten vor Cyberangriffen und Datenverlust.
- Einhaltung gesetzlicher Anforderungen (z. B. DSGVO, IT-Sicherheitsgesetz).

- Erhöhung des Sicherheitsbewusstseins durch klare Prozesse und Schulungen.
- Verbesserung der Geschäftskontinuität durch systematisches Risikomanagement.

11.16 Security by Design

Security by Design ist ein Konzept, bei dem IT-Systeme, Software und Prozesse von Anfang an mit Sicherheitsmechanismen ausgestattet werden. Es basiert auf der Idee, Sicherheitsrisiken proaktiv zu minimieren, anstatt sie nachträglich zu beheben.

Prinzipien

- Minimaler Zugriff (Least Privilege Principle): Benutzer und Prozesse erhalten nur die minimal notwendigen Rechte.
- Standardmäßig sicher (Secure Defaults): Voreinstellungen sollten sicher sein (z. B. starke Passwörter, deaktivierte unsichere Funktionen).
- Fehlertoleranz (Fail-Secure): Systeme sollen auch bei Fehlern sicher bleiben, z. B. durch automatische Sperrmechanismen.
- Trennung von Funktionen (Separation of Duties): Kritische Aktionen erfordern mehrere Berechtigungen oder Bestätigungen.
- Ende-zu-Ende-Verschlüsselung: Schutz der Daten während Speicherung und Übertragung.
- Sichere Entwicklungsmethoden: Secure Coding-Praktiken (z. B. OWASP Top 10 zur Vermeidung von Schwachstellen).

Umsetzung

- Bedrohungsanalysen bereits in der Planungsphase durchführen.
- Sicherheitsmechanismen in den gesamten Software-Development-Lifecycle (SDLC) integrieren.
- Automatisierte Sicherheitstests und regelmäßige Code-Reviews nutzen.
- Security Audits und Penetrationstests durchführen, um Schwachstellen frühzeitig zu erkennen.

Vorteile

- Geringere Kosten für nachträgliche Sicherheitsmaßnahmen.

- Schutz vor Datenlecks, Cyberangriffen und Compliance-Verstößen.
- Verbesserung des Vertrauens der Nutzer durch sichere Systeme.

11.17 Security by Default

Security by Default bedeutet, dass IT-Systeme und Software standardmäßig mit sicheren Einstellungen ausgeliefert werden. Nutzer müssen Sicherheitsmechanismen nicht manuell aktivieren, sondern erhalten bereits ab Werk eine sichere Konfiguration.

Prinzipien

- **Sichere Voreinstellungen:** Standardmäßig sind nur sichere Funktionen aktiviert, unsichere Features sind deaktiviert.
- **Minimaler Zugriff (Least Privilege):** Benutzer und Prozesse erhalten nur die notwendigsten Rechte.
- **Deaktivierung unsicherer Funktionen:** Nicht benötigte Dienste, Ports oder Schnittstellen sind standardmäßig deaktiviert.
- **Starke Authentifizierung:** Vorgabe sicherer Passwörter, Multi-Faktor-Authentifizierung (MFA).
- **Automatische Updates:** Sicherheitsupdates werden standardmäßig aktiviert und regelmäßig installiert.

Umsetzung

- Betriebssysteme liefern standardmäßig aktivierte Firewalls und Verschlüsselung.
- Webbrowser blockieren unsichere Inhalte und setzen HTTPS voraus.
- Cloud-Dienste aktivieren Datenverschlüsselung und Zugriffsbeschränkungen.
- IoT-Geräte setzen starke Passwörter und verschlüsselte Kommunikation als Standard.

Vorteile

- Reduzierung von Sicherheitsrisiken, da Nutzer nicht manuell Einstellungen anpassen müssen.
- Bessere Benutzerfreundlichkeit, da Sicherheit ohne zusätzliches Eingreifen gewährleistet ist.

- Erfüllung von Compliance-Vorgaben (z. B. DSGVO, ISO 27001) durch sichere Grundkonfiguration.

11.18 Härtung des Betriebssystems

Die Härtung eines Betriebssystems (OS Hardening) umfasst Maßnahmen zur Reduzierung von Sicherheitsrisiken durch das Deaktivieren unnötiger Dienste, das Einschränken von Berechtigungen und die Implementierung von Sicherheitsmechanismen.

Maßnahmen

Minimierung der Angriffsfläche

- Nicht benötigte Dienste und Ports deaktivieren
- Überflüssige Benutzerkonten entfernen oder sperren
- Unnötige Software und Komponenten deinstallieren

Starke Zugriffskontrollen

- Prinzip der geringsten Rechte (Least Privilege Principle) umsetzen
- Passwort-Richtlinien durchsetzen (z. B. Mindestlänge, Ablaufdatum)
- Multi-Faktor-Authentifizierung (MFA) aktivieren

System- und Netzwerksicherheit

- Host-Firewall aktivieren und konfigurieren
- Antiviren- und Endpoint-Schutzlösungen einsetzen
- Protokollierung (Logging) und Überwachung aktivieren

Software- und Patch-Management

- Regelmäßige Sicherheitsupdates installieren
- Automatische Updates aktivieren, wenn möglich
- Software nur aus vertrauenswürdigen Quellen installieren

Daten- und Speicherschutz

- Festplattenverschlüsselung (z. B. BitLocker, LUKS) aktivieren
- USB- und externe Speichermedien einschränken oder deaktivieren

- Zugriffsrechte auf sensible Dateien und Verzeichnisse einschränken

Automatisierte Härtung

- Security Baselines (z. B. CIS Benchmarks, BSI IT-Grundschutz) verwenden
- Härtungsskripte und Tools nutzen (z. B. Microsoft Security Compliance Toolkit, Lynis für Linux)

Vorteile

- Schutz vor Cyberangriffen, Malware und Exploits
- Minimierung von Sicherheitslücken durch reduzierte Angriffsfläche
- Erfüllung von Compliance-Anforderungen (z. B. DSGVO, ISO 27001)

11.19 Datensicherungsverfahren

Datensicherung (Backup) ist eine zentrale Maßnahme zur Wiederherstellung von Daten im Falle von Hardware-Ausfällen, Cyberangriffen oder menschlichen Fehlern.

Backup-Arten

Voll-Backup (Full Backup)

- Es wird eine komplette Kopie aller Daten erstellt.
- Vorteil: Schnelle Wiederherstellung.
- Nachteil: Hoher Speicherbedarf und lange Sicherungsdauer.

Inkrementelles Backup

- Es werden nur die seit dem letzten Backup geänderten Daten gesichert.
- Vorteil: Schnelle Sicherung, wenig Speicherverbrauch.
- Nachteil: Wiederherstellung dauert länger, da mehrere Backup-Stände benötigt werden.

Differenzielles Backup

- Sichert alle seit dem letzten Voll-Backup geänderten Dateien.

- **Vorteil:** Schnellere Wiederherstellung als beim inkrementellen Backup.
- **Nachteil:** Benötigt mehr Speicherplatz als inkrementelle Backups.

Spiegelung (Mirroring)

- Echtzeit-Kopie der Daten auf ein zweites Speichermedium.
- **Vorteil:** Sofortige Verfügbarkeit der Daten.
- **Nachteil:** Kein Schutz vor logischen Fehlern oder Malware, da fehlerhafte Daten ebenfalls gespiegelt werden.

Backup-Strategien

3-2-1-Backup-Regel

- 3 Kopien der Daten (Original + zwei Backups).
- 2 verschiedene Medien (z. B. externe Festplatte und Cloud).
- 1 Kopie extern (z. B. Offsite-Backup in einem anderen Rechenzentrum).

Cold, Warm & Hot Backups

- **Cold Backup:** Offline-Sicherung, benötigt manuelle Wiederherstellung.
- **Warm Backup:** Schnell aktivierbare Sicherung mit regelmäßigen Updates.
- **Hot Backup:** Ständig synchronisierte Live-Kopie für sofortige Nutzung.

Air-Gapped Backup

- Datensicherung auf einem nicht mit dem Netzwerk verbundenen System als Schutz vor Ransomware.

Speicherorte für Backups

- **Lokale Backups:** Externe Festplatten, NAS-Systeme.
- **Cloud-Backups:** Online-Speicher (z. B. AWS, Microsoft Azure, Google Drive).
- **Bandlaufwerke:** Langlebig, aber langsamer Zugriff.

Wichtige Backup-Anforderungen

- Regelmäßige Backups (z. B. täglich, wöchentlich, monatlich).
- Automatisierung zur Vermeidung menschlicher Fehler.
- Verschlüsselung und Zugriffsschutz für vertrauliche Daten.
- Regelmäßige Tests der Wiederherstellung (Disaster Recovery Tests)

11.20 Verschlüsselungstechniken

Verschlüsselung dient dem Schutz von Daten vor unbefugtem Zugriff, indem sie in eine unlesbare Form umgewandelt werden. Es gibt drei Hauptarten: symmetrische, asymmetrische und hybride Verschlüsselung.

Symmetrische Verschlüsselung

Bei der symmetrischen Verschlüsselung wird für Ver- und Entschlüsselung derselbe Schlüssel verwendet.

Beispiele:

- AES (Advanced Encryption Standard)
- DES (Data Encryption Standard, veraltet)

Vorteile:

- Sehr schnell und effizient, da nur ein Schlüssel verwendet wird.
- Gut geeignet für große Datenmengen.

Nachteile:

- Sichere Schlüsselverteilung ist problematisch.
- Falls der Schlüssel kompromittiert wird, sind die Daten nicht mehr sicher.

Asymmetrische Verschlüsselung

Bei der asymmetrischen Verschlüsselung gibt es zwei Schlüssel:

- Öffentlicher Schlüssel: Zum Verschlüsseln von Daten.
- Privater Schlüssel: Zum Entschlüsseln der Daten.

Beispiele: